VITALSTACK · DESIGN DOCUMENT

Premium plans: secure payments and protected content

Plans and prices, course catalogue, sign-up to purchase flow, 2FA and device limit, content protection, permissions, monitoring and the build plan.

Version	1.0 (draft for approval)
Date	30 October 2026
Builds on	Theme 4.7.0 (branch `claude/confident-maxwell-xca6ty`)
Status	Design only. Development starts when the owner says “start”.

In one line: only signed-up, email-confirmed, subscribed readers with 2FA can buy; payments are confirmed twice by signature; premium lessons are served one at a time to the paying reader's own phone or computer, stamped with their identity, and never placed where a copier can grab them.

1. Summary

Owner's decisions (30 Oct 2026)

Topic	Decision	Where
Plans and prices	Set by market; the goal is that courses sell.	§3
Devices	One phone and one computer per account, at the same time.	§9
Who can buy	Only signed-in readers who confirmed their email and subscribed. 2FA required. Strong security.	§7, §9
Courses	Category-wise: Gen AI and Agentic AI as the lead category.	§4
Protection	Nothing should leak or be edited. Premium readers can only read, write and update their own data in the premium tools.	§10, §11

Two honest limits (and how we answer them)

Wish	Reality	What we do instead
Block screenshots	No website can block a phone screenshot, screen recording or a second phone's camera. Sites that claim it are wrong.	Make every leak **traceable**: visible and invisible watermark with the reader's identity, so one leaked image points to one account, which we close. The Android app (Phase 6) can truly block screenshots.
“Encryption so no one can copy”	Text on the screen must be readable, so it is decrypted in the reader's browser. Encryption protects data in transit and at rest, not from the person paying to read it.	Use encryption where it helps (HTTPS, secrets, backups, optional lesson storage) and stop copying with delivery rules, copy blocking, rate limits and watermarks (§10).

2. What is already built (theme 4.7.0)

Area	Already live in the code	This design adds
Accounts	Sign up, email confirmation, lesson-email subscription, readers never see wp-admin	Purchase checklist, 2FA, device limit
Login security	Lockout after 10 misses, same error for every failure, no user listing, XML-RPC and app passwords off, security headers	2FA, step-up check before payment, admin 2FA required, alerts
Payments	Razorpay orders, server-side prices, HMAC-SHA256 checks, signed webhook, one grant per order, receipt email, practice checkout	New prices, lifetime plan, coupons, AutoPay monthly, refund/dispute handling, invoice numbers, daily reconciliation
Premium	Data Scientist and Gen AI Developer tracks, lesson preview + lock, premium lessons hidden from search and REST	Agentic AI track, premium content API, watermarks, copy/print block, rate limits, workspace
Learning	Visualisers, quizzes, certificates, XP, streaks, study buddy, tools	Standard premium lesson template with line-by-line code (§5)

3. Plans and prices

Indian learners compare us with two ends of the market: low-priced single courses during marketplace sales (a few hundred rupees) and bootcamps (tens of thousands to lakhs). We sit in between: the yearly plan costs about as much as a handful of sale courses, but gives full career tracks, projects, certificates and every track we add. Prices below are a starting point to review after 60 days of real sales data.

Plan	₹ (India)	$ (abroad)	What you get	Role in sales
Free	0	0	All free lessons, tools, games, quizzes; ads shown	Traffic from Google, AdSense, trust
Pro Monthly	399 / month	9	All premium tracks; UPI AutoPay; cancel any time	Low first step; makes yearly look cheap
Career Track (1 year)	1,999	39	One track with its projects and certificate	For people who want one goal
Pro Yearly ★ best value	2,999 / year	69	All tracks + everything added during the year	Main plan to push (≈ ₹250 / month, 37% less than monthly)
Founder Lifetime	6,999 once	149	All current and future tracks for life; first 200 buyers only	Early cash and urgency at launch

- **Launch offer:** Pro Yearly at ₹1,999 for the first 30 days (code `LAUNCH`). Campus codes (e.g. `STUDENT20`) for colleges and ambassadors. Coupons are checked only on the server, with limits on use count and expiry.

- **Refunds:** full refund within 7 days if under 30% of lessons were opened. This builds trust without letting someone read everything and refund.
- **No ads** on any page for premium readers.
- **Changes from today:** Monthly ₹499→399, single track ₹2,999→1,999, yearly ₹4,999→2,999, new Lifetime plan. Prices stay editable in *Settings → VitalStack Payments*.

4. Course catalogue (category-wise)

Category	Track	Status
Generative and Agentic AI (lead category)	**Agentic AI Engineer** (new flagship, below)	New
	Gen AI Developer: LLMs, APIs, RAG, LangChain, fine-tuning, deployment	Syllabus live; its "AI Agents" module becomes a short intro that leads into the flagship
	Spring AI for Java developers (uses our big Java audience)	Later
Data and ML	Data Scientist: statistics, ML, SQL, Power BI, deep learning, 6 projects	Syllabus live
Career Pro (later)	Java + Spring Boot backend, DSA interview pro	Later

Agentic AI Engineer: syllabus

1. **Agent basics:** the plan → act → observe loop; when not to use an agent
2. **Tool use in depth:** function calling, JSON schemas, errors and retries
3. **Memory and state:** short-term, long-term, vector memory
4. **Reasoning patterns:** ReAct, plan-and-execute, reflection
5. **MCP:** build an MCP server and connect it to an agent
6. **Frameworks compared:** LangGraph, CrewAI, Claude Agent SDK, OpenAI Agents SDK
7. **Multi-agent systems:** orchestrator–worker, hand-offs, shared state
8. **Evals and tracing:** test sets, LLM-as-judge, observability
9. **Safety:** prompt injection, permissions, human approval, sandboxes
10. **Production:** cost, latency, caching, deployment, monitoring
11. **Capstones:** research agent, support agent with tools, coding agent, browser agent

5. Premium lesson standard

Every premium lesson follows one template so it works for a struggling student and a topper alike:

1. **Goal and time**: what you will be able to do, in how many minutes.

2. **Animated visual** (viz.js) of the idea before any code.
3. **Two depths**: a *Simple* explanation and a *Deep dive* switch for toppers.
4. **Line-by-line code**: every line has its own explanation; tapping a line highlights it in the animation.
5. **Try it**: editor with automatic checks.
6. **3-question quiz**, then a **mini task**.
7. **Interview questions** and a **recap card**. Study buddy question halfway; XP on finish.

Quality gate: every code sample is run by an automated test before publishing, with library versions pinned.

6. System architecture

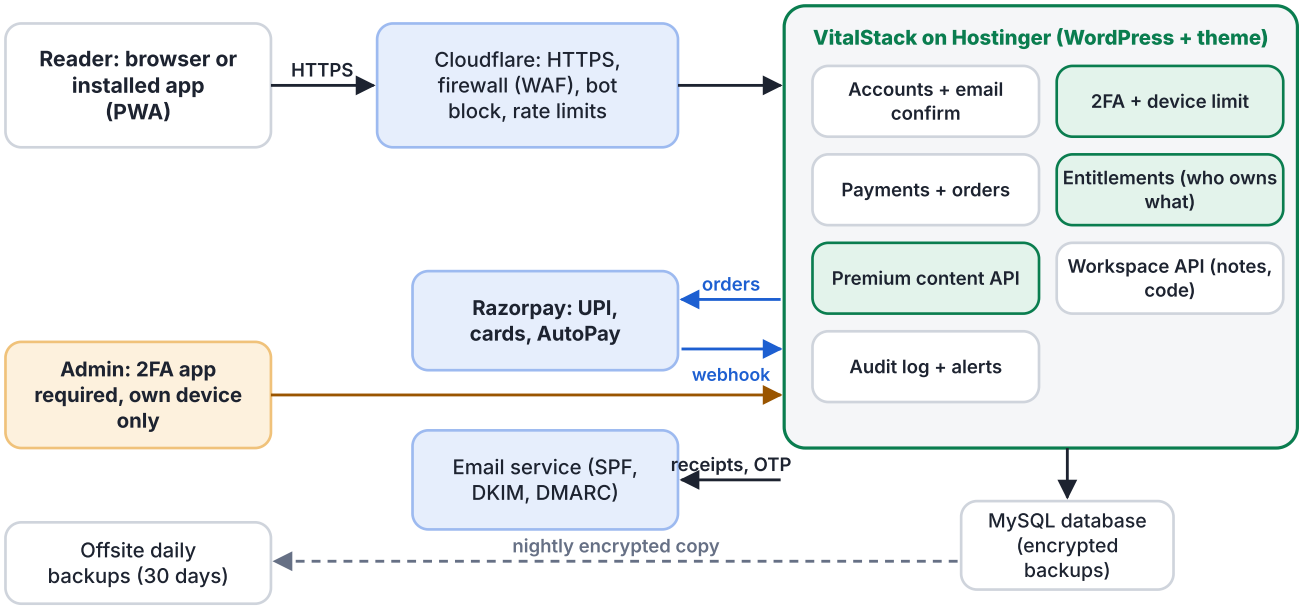


Figure 1. Reader traffic passes through Cloudflare. Razorpay and the email service are outside services; only signed messages from Razorpay are believed.

7. Who can buy

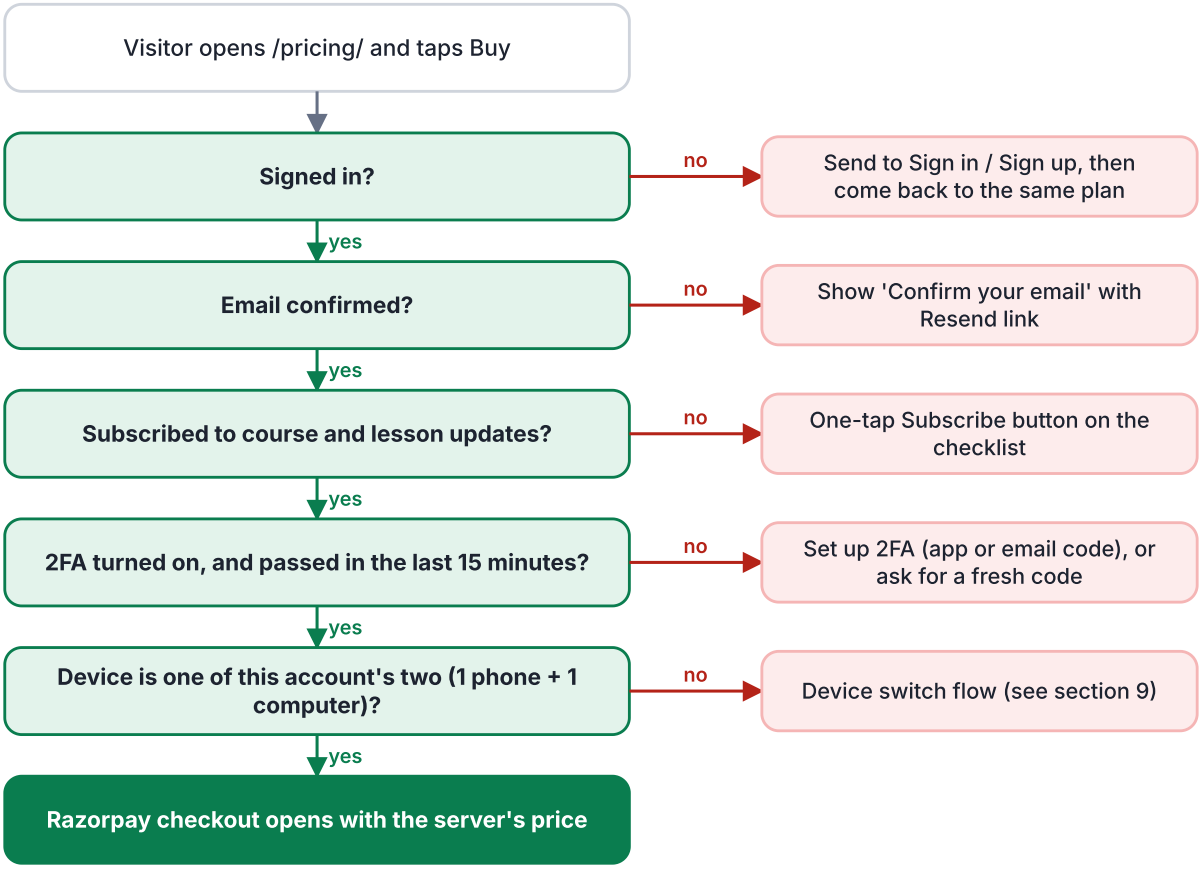


Figure 2. The Buy button shows the same checklist style as the certificate card, so each missing step is one tap away.

Email consent: course and lesson updates are part of the service, so making them required is fine. Promotional emails must stay a separate, optional choice with one-click unsubscribe (India's Digital Personal Data Protection Act, 2023).

8. Payment flow

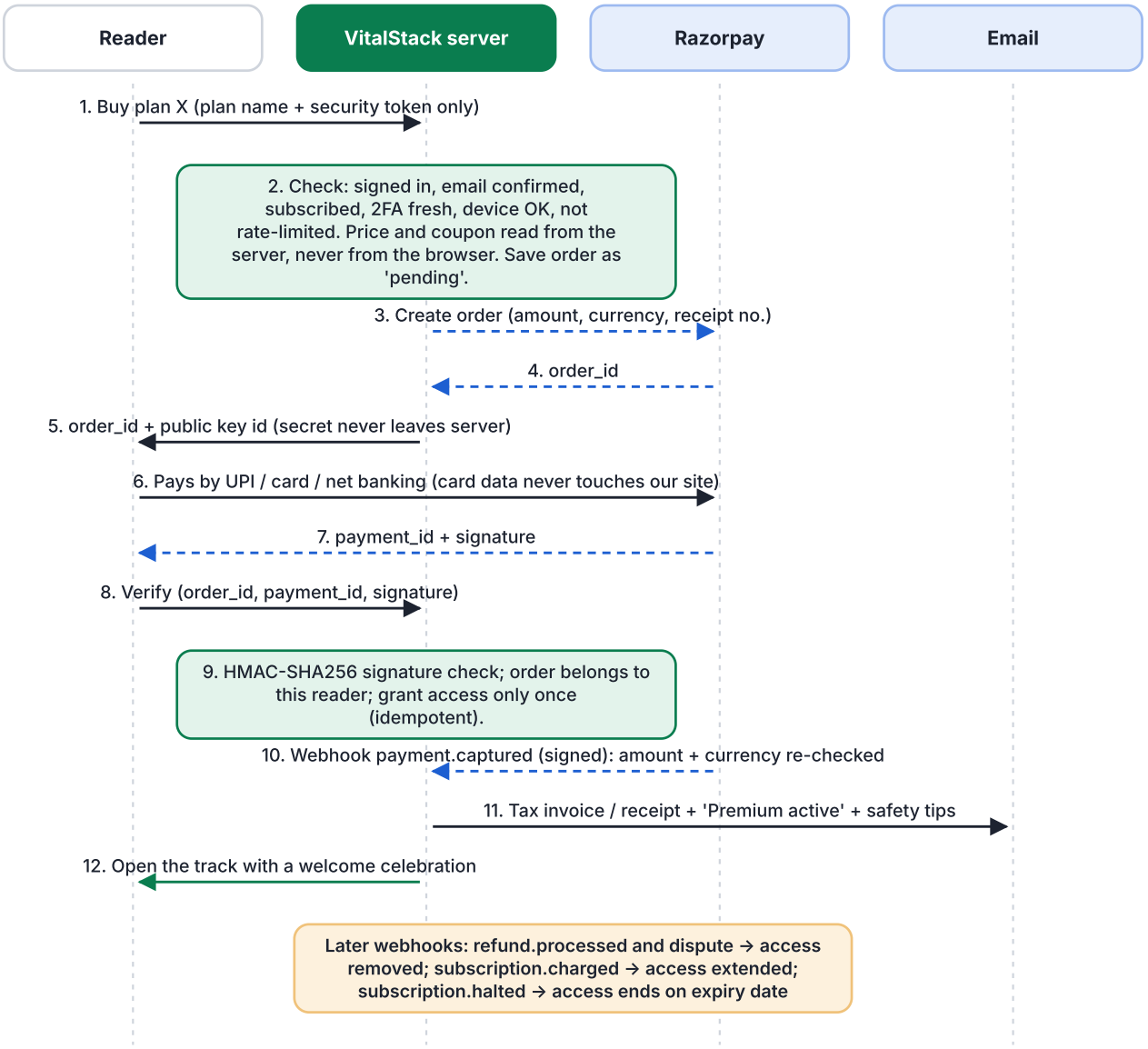


Figure 3. Steps 1–10 already exist; this design adds the step-up checks in step 2, invoice numbers, and the later webhooks.

Payment additions

- **Monthly via Razorpay Subscriptions** (UPI AutoPay / card mandate), with a reminder email 3 days before each charge.
- **Sequential invoice numbers** (VS/2026-27/0001), buyer name and optional GSTIN, sent as a PDF. Tax rules: confirm with a CA (GST registration, rates for online education).
- **Refund or dispute** webhook removes access at once and logs it.
- **Daily reconciliation:** compare Razorpay captured payments with orders; email the admin about any mismatch.
- **Alert** if a payment is captured but access is not granted within 10 minutes.

9. Sign-in, 2FA and the device limit

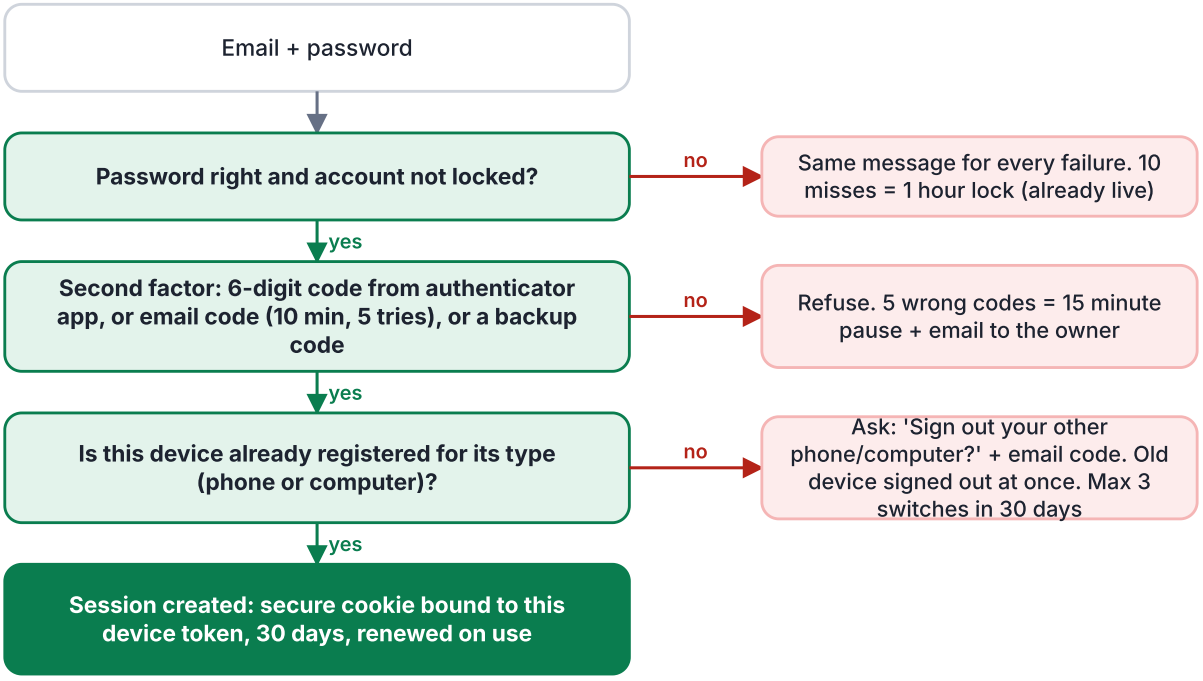


Figure 4. Sign-in for premium readers. Free readers can keep password-only sign-in until they buy.

- **2FA choices:** authenticator app (Google Authenticator, Microsoft Authenticator; recommended) or a 6-digit email code. Ten one-time backup codes at setup.
- **Device rule:** one phone or tablet, and one laptop or desktop, signed in at the same time. Signing in on a third device asks to sign out the old one of the same type, with an email code. At most 3 switches in 30 days; after that, support checks the account.
- **How a device is recognised:** a random device token in a secure, HttpOnly cookie, linked to the session on the server. The device type comes from the browser and can be faked, so the rule is backed by watermarks and alerts.
- **Sessions:** 30 days, renewed on use, revocable from “My devices” in the account page. Password change signs out every device.
- **Lost phone:** use a backup code, or support verifies the order ID and email.
- **Admins:** authenticator app required (no email codes), 12-hour sessions, email alert on every admin sign-in from a new device.

10. Premium content protection

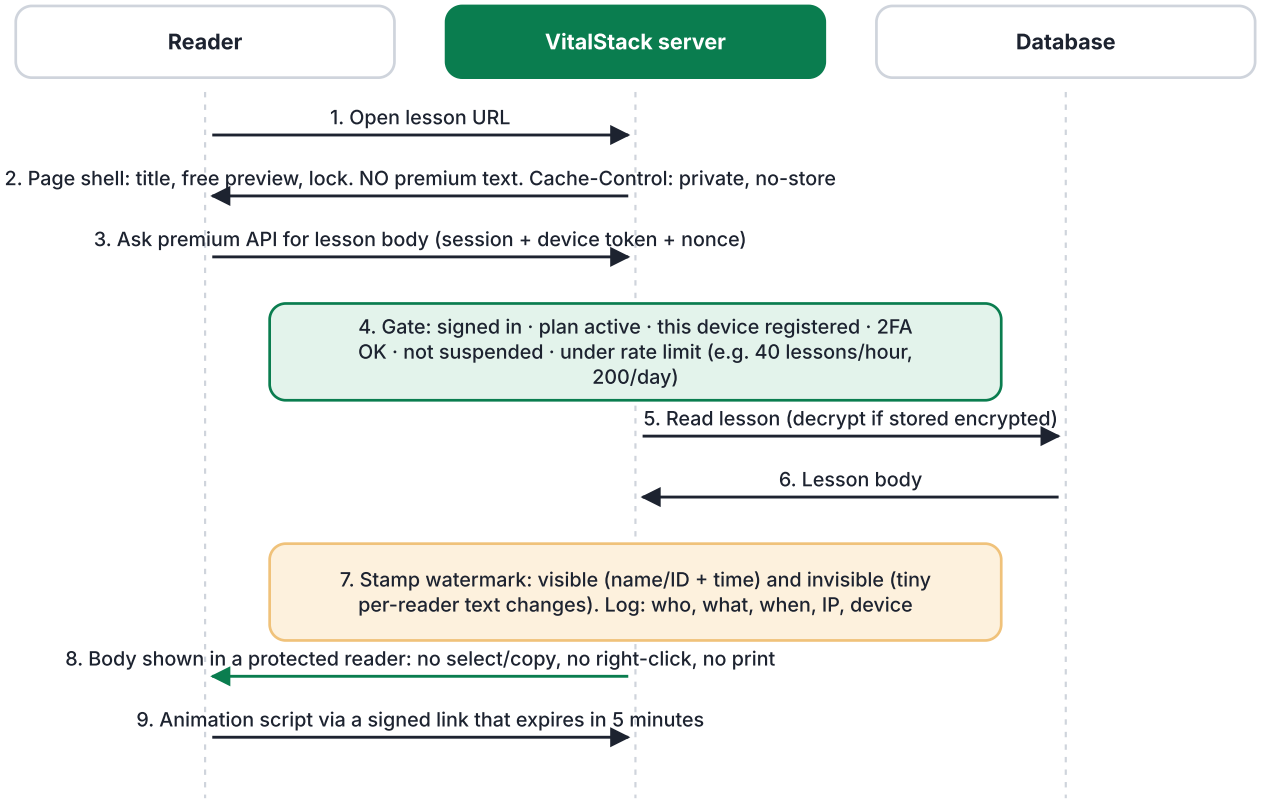


Figure 5. A premium lesson is fetched per reader, per device, and stamped before it leaves the server.



Figure 6. Eight layers. Each one catches what the outer layer misses.

Encryption: what it does and does not protect

Where	Protection	Stops
Between reader and site	HTTPS (TLS 1.2+) with HSTS	Wi-Fi snooping, tampering
Payment keys and secrets	Encrypted at rest (already live) or kept in wp-config.php	Leaks from a database copy
Premium lesson storage (optional)	AES-256-GCM with the key in wp-config.php	Someone with only a database dump
Backups	Encrypted, offsite, 30 days	Stolen backup files
Animation scripts	Minified and obfuscated, served by 5-minute signed links	Easy reuse of our visualisers (slows copying, cannot fully stop it)
The screen	Not possible	Covered by watermark + traceability

11. Roles and permissions

Action	Visitor	Free reader	Premium reader	Editor (future)	Admin
Read free lessons, tools	✓	✓	✓	✓	✓
Read premium lessons	preview	preview	✓ own plan	✓	✓
Own notes, saved code, projects, bookmarks	–	limited	✓ create, read, update, delete **own only**	own only	support view
See another reader's data	–	–	–	–	✓ (logged)
Edit lessons and courses	–	–	–	✓ (2FA, logged)	✓ (2FA, logged)
Prices, refunds, give access	–	–	–	–	✓
Export / delete my data	–	✓	✓	✓	✓

- **Workspace rule:** every saved item stores its owner. Each API call checks owner = signed-in reader, a fresh nonce, input size and type, and a rate limit. Readers can never change lesson content, only their own workspace.
- **Content cannot be edited by outsiders:** readers have no editing rights; the wp-admin file editor is off (already live); editors and admins need 2FA; every content change is kept as a revision and written to the audit log; theme files are deployed only from Git, and a file-integrity check emails the admin about any unexpected change.

12. Monitoring and alerts

Signal	Automatic action	Admin told?
More than 40 premium lessons in an hour, or 200 in a day	Pause premium for 1 hour, ask for a 2FA code	Yes
Same account in two far-apart cities within an hour	Ask for 2FA again on both	Yes
Third device switch in 30 days	Block switching; route to support	Yes
Webhook signature fails	Ignore request	Yes
Payment captured, no access after 10 minutes	Retry grant	Yes
Refund or dispute	Remove access	Yes
Admin sign-in from a new device	Require 2FA app	Yes (to the admin)
Weekly	Security digest email: sign-ins, locks, alerts, sales, refunds	

13. If content leaks

1. Read the watermark in the leaked image or text (visible ID, or the invisible pattern via an admin tool).
2. Check that reader's access log to confirm.
3. Suspend the account at once (one click), and sign out every device.
4. Send takedown notices to the platform (Telegram, YouTube, Google, file sites).
5. Close the account under the Terms (no refund for sharing), and keep a record.
6. If the same lesson leaks again, change its invisible watermark pattern.

14. Legal and business checklist

Item	Must say or do
Terms of Use	Personal, non-transferable licence; no sharing of accounts or content; account closed without refund for sharing; watermarking and logging disclosed.
Privacy Policy (DPDP Act 2023)	What we collect (account, device token, IP, access log), why, how long, readers' rights (access, correction, deletion), grievance contact.
Refund and Cancellation	7-day rule above; how to cancel AutoPay; digital product, no shipping (Razorpay needs this page).
Invoices and tax	Invoice numbering and GST: confirm registration and rates with a CA.
Razorpay	KYC done; live keys in wp-config.php; webhook set for live mode.

15. Build plan

Phase	What	Rough time
1. Account security	Buy checklist, 2FA (app + email + backup codes), device limit and “My devices”, admin 2FA required, step-up before payment	1–2 weeks
2. Payment hardening	New prices and Lifetime plan, coupons, AutoPay monthly, refund/dispute webhooks, invoice PDF, reconciliation, alerts	1–2 weeks
3. Content protection	Premium content API, no-store, watermarks, copy/print block, rate limits, signed scripts, audit log, leak tool	1–2 weeks
4. Premium workspace	Notes, saved code, projects with owner-only permissions; export and delete my data	1–2 weeks
5. Agentic AI track	Lesson template with line-by-line code; modules published one by one	Ongoing
6. Later	Android app with real screenshot blocking; Spring AI track	After launch

Times are rough and depend on review rounds. Each phase is tested on a staging copy with the practice checkout before going live.

16. Needed from the owner

1. Approve the prices in §3 (or change them).
2. Razorpay: KYC status, and whether international payments are enabled.
3. GST: registered or not (ask a CA).
4. A free Cloudflare account, to put the site behind it.
5. An email service for sign-in codes and receipts (for example Brevo, Amazon SES, or Hostinger mail) with SPF, DKIM and DMARC set.
6. A support email address for lost-phone and refund requests.
7. Legal pages reviewed by a lawyer or CA before launch.
8. A Hostinger staging site for testing each phase.